

# SENTINAL SECURITY AUDIT REPORT

Target Scope: https://ginandjuice.shop | Scan Mode: SAFE | Auth: DEV\_MODE | Date: September 04, 2026 at 07:52 UTC

| Security Score | DAST Coverage         | Critical Flaws | High Flaws | Total Findings |
|----------------|-----------------------|----------------|------------|----------------|
| 73.3/100       | 84.4% (FULL COVERAGE) | 1              | 1          | 14             |

## 1. Target Connectivity & Blocking Diagnostics

|                    |              |                      |                       |
|--------------------|--------------|----------------------|-----------------------|
| Reachability       | REACHABLE    | TLS Protocol         | TLSv1.2               |
| Application Access | UNRESTRICTED | WAF / Bot Protection | None Detected         |
| Finding Confidence | FULL         | Coverage Status      | FULL COVERAGE (84.4%) |

Recommendation: Target is directly accessible.

## 2. Executive Summary

**\*\*Security Assessment Executive Summary\*\***

**\*\*Overall Posture:\*\* CRITICAL POSTURE**

The automated assessment of https://ginandjuice.shop identified immediate critical exposures requiring urgent remediation. A total of 14 findings were recorded, including 1 Critical and 1 High severity vulnerabilities.

**\*\*Key Risk Highlights:\*\***

- Total Discovered Findings: 14 (Critical: 1, High: 1, Medium: 4, Low: 8)
- Correlated Exploit Chains: 0
- Primary Concern Areas: Injection, Vulnerable Dependency, Session Management, Cloud Credentials

Leadership is advised to authorize immediate sprint allocation for remediation of critical issues and enforce automated security gating in CI/CD pipelines.

## 4. Prioritized Vulnerability & Threat Inventory

| Severity & Risk                                                           | Engine                | Vulnerability & Threat Scenario                                                                                                                                                                                                                                               | Location & Remediation                                                                                                                                            |
|---------------------------------------------------------------------------|-----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>HIGH</b><br>Risk: 94.3/100<br><b>Blast:</b> Database Takeover & Sens   | SAST<br>sentinal-sast | <b>Potential SQL Injection via Unsanitized Query Execution</b><br><b>Threat:</b> An attacker can supply crafted SQL payloads to bypass authentication barriers, extract proprietary customer PII and database tables, modify financial or user records, or execute ad..       | src/auth.py<br><b>Fix:</b> Use parameterized queries (e.g. `cursor.execute('SELECT * FROM users WHERE id = %s', (user_id,))`) or an ORM with parameter binding... |
| <b>MEDIUM</b><br>Risk: 54.5/100<br><b>Blast:</b> Third-Party Component Ex | SCA<br>osv-scanner    | <b>Vulnerable Dependency: lodash (4.17.15) - GHSA-29mw-wpgm-hmr9</b><br><b>Threat:</b> An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in .. | package.json<br><b>Fix:</b> Upgrade lodash to a secure version. Upgrade to latest version...                                                                      |
| <b>MEDIUM</b><br>Risk: 54.5/100<br><b>Blast:</b> Third-Party Component Ex | SCA<br>osv-scanner    | <b>Vulnerable Dependency: django (3.2.0) - GHSA-2gwj-7jmv-h26r</b><br><b>Threat:</b> An outdated third-party dependency contains known, publicly documented CVEs with available exploit payloads, allowing automated scanners and threat actors to target known flaws in ..   | requirements.txt<br><b>Fix:</b> Upgrade django to a secure version. Upgrade to latest version...                                                                  |

|                                                                              |                                     |                                                                                                                                                                                                                                                                                               |                                                                                                                                                                           |
|------------------------------------------------------------------------------|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>CRITICAL</b><br>Risk: 100.0/100<br><b>Blast:</b> Cloud & Third-Party Serv | <b>SECRETS</b><br>gitleaks          | <b>Exposed Secret: AWS Access Key ID</b><br><b>Threat:</b> Hardcoded credentials, API keys, or private cryptographic keys exposed in code or public responses allow adversaries to authenticate directly to third-party SaaS services, cloud ac..                                             | src/auth.py<br><b>Fix:</b> Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or BFG, and store secrets in environment v.. |
| <b>LOW</b><br>Risk: 25.5/100<br><b>Blast:</b> Defense Degradation & Tr       | <b>DAST</b><br>ZAP, HEADER_ANALYZER | <b>OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB'</b><br><b>Threat:</b> Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack.. | /<br><b>Fix:</b> Ensure your application adds HttpOnly, Secure, SameSite to the cookie attributes...                                                                      |
| <b>LOW</b><br>Risk: 23.2/100<br><b>Blast:</b> Defense Degradation & Tr       | <b>DAST</b><br>ZAP                  | <b>OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB'</b><br><b>Threat:</b> Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack.. | /catalog<br><b>Fix:</b> Add HttpOnly, Secure, SameSite attributes to all Set-Cookie response headers...                                                                   |
| <b>LOW</b><br>Risk: 23.2/100<br><b>Blast:</b> Defense Degradation & Tr       | <b>DAST</b><br>ZAP                  | <b>OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB'</b><br><b>Threat:</b> Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack.. | /blog<br><b>Fix:</b> Add HttpOnly, Secure, SameSite attributes to all Set-Cookie response headers...                                                                      |
| <b>LOW</b><br>Risk: 23.2/100<br><b>Blast:</b> Defense Degradation & Tr       | <b>DAST</b><br>ZAP                  | <b>OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB'</b><br><b>Threat:</b> Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack.. | /about<br><b>Fix:</b> Add HttpOnly, Secure, SameSite attributes to all Set-Cookie response headers...                                                                     |
| <b>LOW</b><br>Risk: 23.2/100<br><b>Blast:</b> Defense Degradation & Tr       | <b>DAST</b><br>ZAP                  | <b>OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB'</b><br><b>Threat:</b> Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack.. | /my-account<br><b>Fix:</b> Add HttpOnly, Secure, SameSite attributes to all Set-Cookie response headers...                                                                |
| <b>LOW</b><br>Risk: 23.2/100<br><b>Blast:</b> Defense Degradation & Tr       | <b>DAST</b><br>ZAP                  | <b>OWASP ZAP: Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB'</b><br><b>Threat:</b> Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack.. | /login<br><b>Fix:</b> Add HttpOnly, Secure, SameSite attributes to all Set-Cookie response headers...                                                                     |
| <b>MEDIUM</b><br>Risk: 49.9/100<br><b>Blast:</b> Defense Degradation & Tr    | <b>WEB</b><br>HEADER_ANALYZER       | <b>Missing HTTP Strict Transport Security (HSTS) Header</b><br><b>Threat:</b> Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..                          | /<br><b>Fix:</b> Add `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload` header to all HTTPS responses...                                           |
| <b>MEDIUM</b><br>Risk: 49.9/100<br><b>Blast:</b> Defense Degradation & Tr    | <b>WEB</b><br>HEADER_ANALYZER       | <b>Missing Content Security Policy (CSP) Header</b><br><b>Threat:</b> Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..                                  | /<br><b>Fix:</b> Implement a strong `Content-Security-Policy` header (e.g. `default-src 'self'; script-src 'self'; object-src 'none'`)...                                 |
| <b>LOW</b><br>Risk: 22.2/100<br><b>Blast:</b> Defense Degradation & Tr       | <b>WEB</b><br>HEADER_ANALYZER       | <b>Missing X-Content-Type-Options Header</b><br><b>Threat:</b> Missing transport or browser security controls allow adversaries on adjacent networks or untrusted origins to intercept cleartext communications, frame the application in Clickjack..                                         | /<br><b>Fix:</b> Configure `Permissions-Policy: camera=(), microphone=(), geolocation=()` to disable unused browser APIs...                                               |

|                                                                        |                               |                                                                                                                                                                                                                                                |                                                                                                |
|------------------------------------------------------------------------|-------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------|
| <b>LOW</b><br>Risk: 30.2/100<br><b>Blast:</b> Cloud & Third-Party Serv | <b>WEB</b><br>HEADER_ANALYZER | <b>Missing Referrer-Policy Header</b><br><b>Threat:</b> Hardcoded credentials, API keys, or private cryptographic keys exposed in code or public responses allow adversaries to authenticate directly to third-party SaaS services, cloud ac.. | / <b>Fix:</b> Configure `Referrer-Policy: strict-origin-when-cross-origin` or `no-referrer`... |
|------------------------------------------------------------------------|-------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------|

## 5. Strategic Remediation Playbook

- \*\*Step-by-Step Remediation Actions:\*\***
- **\*\*Cloud Credentials:\*\*** Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or BFG, and store secrets in environment variables or a Secret Vault.
  - **\*\*Injection:\*\*** Use parameterized queries (e.g. `cursor.execute('SELECT \* FROM users WHERE id = %s', (user\_id,))`) or an ORM with parameter binding.
  - **\*\*Vulnerable Dependency:\*\*** Upgrade lodash to a secure version. Upgrade to latest version.
  - **\*\*Cryptographic Failures:\*\*** Add `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload` header to all HTTPS responses.